

GRC102 – WEEK 2 PRACTICAL LABORATORY

SECURITY POLICY DEVELOPMENT LIFECYCLE

NexusTech Solutions

Student Name: Sandra Aganyi

Registration Number: C11/26/CGRCE/17565

Course: GRC102

Role: Information Security Manager

Submission Date: 18 September 2026

EVIDENCE BUNDLE 1 – SECURITY POLICY HIERARCHY

Task 1: Establish the Security Policy Hierarchy

1.1 Introduction

NexusTech Solutions has grown from 50 to 250 employees and now serves clients in the financial and healthcare sectors. The existing five-year-old "IT Rules" document combines policy requirements, technical instructions and general recommendations.

This creates uncertainty about which requirements are mandatory, who is responsible for implementing them and how security requirements should be maintained.

A structured documentation hierarchy will separate organisational requirements from implementation instructions and recommendations.

1.2 Policy Documentation Hierarchy

 Document Type	Purpose	Authority	Mandatory or Recommended	Level of Detail
Policy	Establishes high-level organisational requirements, direction and management expectations.	Approved by senior management or designated authority.	Mandatory	High level; explains what must be done and why.
Standard	Defines specific minimum security requirements needed to support a policy.	Approved by the relevant security/governance authority.	Mandatory	More specific than policy; defines minimum requirements.
Procedure	Provides sequential instructions for carrying out a specific activity.	Approved by the responsible process or system owner.	Mandatory when applicable	Detailed, action-oriented and operational.
Guideline	Provides recommended	Issued by the relevant subject-matter owner.	Recommended unless	Practical advice with flexibility.

	good practice to help users or teams meet policy objectives.		otherwise stated	
--	--	--	-------------------------	--

Key Distinction

A **policy** states what NexusTech requires and why.

A **standard** establishes the minimum technical or operational requirement.

A **procedure** explains how an activity is performed.

A **guideline** provides recommended advice where flexibility is appropriate.

For example, a policy may require multi-factor authentication, a standard may define the minimum authentication requirements, a procedure may explain how Helpdesk provisions MFA, and a guideline may provide advice for users travelling with corporate devices.

1.3 NexusTech Policy Hierarchy

The proposed hierarchy is:

Enterprise Information Security Policy



Topic-Specific Security Policies



Security Standards



Procedures



Guidelines / Checklists / Templates

Example

Information Security Policy



Access Control Policy



Access Control Standard



User Access Request Procedure



Helpdesk Access Request Checklist

This structure prevents technical instructions from being incorrectly placed inside high-level policy documents.

1.4 Categorisation of the Eight Statements

No.	Statement	Classification	Justification
1	All NexusTech employees must use MFA when accessing the corporate network remotely.	Policy	This establishes a mandatory organisational security requirement and states what users must do without explaining how it is implemented.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	This provides sequential instructions explaining exactly how a user performs an MFA configuration task.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	The statement provides recommended security practice rather than an absolute mandatory organisational requirement.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	This establishes a high-level organisational security commitment and direction.
5	All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	This defines a specific mandatory technical requirement that supports the broader security policy.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	The use of "should" makes this recommended security advice rather than a mandatory requirement.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	The statement directs users what action to take and where to report an event, making it an operational instruction.
8	Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase	Standard	This defines specific mandatory password requirements that

	letter, one number and one special character.		establish a minimum security baseline.
--	---	--	--

Important Governance Observation

The old "IT Rules" document should not continue mixing these four document types. The requirements should be separated into the appropriate policy, standard, procedure and guideline documents and maintained under clear ownership.

EVIDENCE BUNDLE 2 – ACCEPTABLE USE POLICY

Task 2: NexusTech Solutions Acceptable Use Policy

Document Control

Field	Information
Policy Title	Acceptable Use Policy
Policy ID	NTS-SEC-AUP-001
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027
Classification	Internal

2.1 Purpose

The purpose of this Acceptable Use Policy is to establish clear requirements for the appropriate use of NexusTech Solutions' information systems, devices, networks, applications and digital resources.

The policy is intended to reduce security, operational, legal and compliance risks arising from misuse of corporate resources, unauthorised software, excessive personal use, unauthorised access and inappropriate handling of information.

2.2 Scope

This policy applies to:

- All NexusTech employees.
- Contractors and consultants.
- Interns and temporary workers.
- Third parties authorised to use NexusTech resources.
- All company-owned or managed devices.
- Approved personally owned devices accessing NexusTech resources.
- Corporate networks and systems.
- Cloud services and applications.

- Corporate accounts and information.

2.3 Acceptable Use

Users **must**:

1. Use NexusTech systems and resources for legitimate business purposes and other authorised activities.
2. Protect usernames, passwords, authentication credentials and other access information.
3. Lock corporate devices when leaving them unattended.
4. Use only authorised applications, software and services for business activities.
5. Protect company and client information from unauthorised access, disclosure, alteration or loss.
6. Follow applicable security policies, standards and procedures.
7. Report suspected phishing, malware, unauthorised access, data loss or other security incidents promptly.
8. Use corporate systems responsibly and in a manner that does not disrupt business operations.
9. Comply with applicable laws, contractual obligations and organisational requirements.
10. Use approved storage and collaboration services when handling NexusTech or client information.

2.4 Prohibited Activities

Users **must not**:

1. Share passwords, authentication tokens or other credentials.
2. Attempt to access systems, accounts or information without authorisation.
3. Bypass or disable security controls without formal authorisation.
4. Install unauthorised software or applications on company-managed devices.
5. Download files or applications from sources that present an unreasonable security risk.
6. Introduce malware, malicious code or other harmful software into NexusTech systems.
7. Use NexusTech systems to conduct illegal activities.
8. Access, copy or disclose confidential information without a legitimate business need.
9. Use corporate resources to harass, threaten or discriminate against other individuals.
10. Engage in activities that intentionally interfere with the availability or performance of NexusTech systems.
11. Store company or client information in unauthorised personal cloud storage services.
12. Connect unauthorised devices to corporate systems where doing so could introduce security risks.

2.5 Reasonable Personal Use

Limited personal use of NexusTech resources may be permitted where it:

- Does not interfere with work responsibilities.
- Does not create a security or compliance risk.
- Does not consume excessive organisational resources.
- Does not involve prohibited or illegal activities.
- Does not involve unauthorised disclosure or storage of company information.

NexusTech may restrict or prohibit personal use where required to protect systems, information or business operations.

2.6 Monitoring

NexusTech may monitor the use of corporate systems, networks, devices and accounts where authorised and permitted by applicable requirements.

Monitoring may be used to:

- Detect security threats.
- Investigate suspected misuse.
- Protect company information.
- Support incident investigations.
- Verify compliance with organisational requirements.

Users should not assume that activity performed using NexusTech systems is completely private.

2.7 Roles and Responsibilities

Users

Users are responsible for:

- Following this policy.
- Protecting their credentials and devices.
- Using resources appropriately.
- Reporting security incidents.
- Completing required security awareness activities.

Information Security Team

The Information Security Team is responsible for:

- Maintaining the policy.
- Providing security guidance.
- Monitoring relevant compliance.
- Supporting investigations.
- Recommending corrective controls.

IT Team

The IT Team is responsible for:

- Implementing technical controls.
- Managing corporate devices and systems.
- Restricting unauthorised software where appropriate.
- Supporting security monitoring and incident response.

Managers

Managers are responsible for:

- Ensuring staff understand relevant requirements.
- Supporting policy compliance.
- Escalating repeated or significant violations.

Human Resources

HR supports disciplinary and employment-related actions where policy violations involve employees.

2.8 Exceptions

Exceptions may be permitted where there is a legitimate business or operational requirement.

An exception request must:

1. Identify the policy requirement involved.
2. Explain the business justification.
3. Identify the associated risk.
4. Identify affected systems or users.
5. Define appropriate compensating controls.

6. Obtain approval from the authorised authority.
7. Include an expiry or review date.

Exceptions should be temporary wherever practical.

2.9 Compliance and Enforcement

NexusTech may investigate suspected violations of this policy.

Depending on the nature and severity of the violation, consequences may include:

- Additional security training.
- Corrective action.
- Temporary or permanent access restriction.
- Disciplinary action.
- Contractual consequences.
- Escalation to management.
- Legal or regulatory action where applicable.

Enforcement should be proportionate and consistent with applicable organisational procedures.

2.10 Review and Version Control

The policy shall be reviewed at least annually and earlier where significant changes occur to:

- Technology.
- Business operations.
- Security risks.
- Legal or regulatory requirements.
- Client requirements.
- Organisational structure.
- Security incidents.

Current Version: 1.0

Next Scheduled Review: 18 September 2027

EVIDENCE BUNDLE 3 – USER ACCESS REQUEST PROCEDURE

Task 3: User Access Request Procedure

Document Control

Field	Information
Procedure Title	User Access Request Procedure
Procedure ID	NTS-SEC-PRO-001
Version	1.0
Procedure Owner	IT Manager
Approving Authority	Information Security Manager
Effective Date	18 September 2026
Review Date	18 September 2027

3.1 Purpose

This procedure establishes a consistent process for requesting, approving, provisioning, modifying and documenting user access to NexusTech systems.

The procedure is intended to reduce unauthorised access and ensure that access is based on business need, approved responsibilities and least-privilege principles.

3.2 Scope

This procedure applies to:

- New employees.
- Existing employees requiring additional access.
- Employees changing roles.
- Contractors.
- Temporary workers.
- Approved third parties.
- Access to corporate applications, systems, networks and cloud services.

3.3 Prerequisites

Before processing an access request, the Helpdesk technician must have access to:

- The approved ticketing/workflow system.
- Relevant user identity information.
- The approved access-role catalogue.
- Manager approval information.
- System or data-owner approval where required.
- Relevant onboarding, transfer or role-change information.

Only authorised Helpdesk or IT personnel may provision access.

3.4 Procedure

Step 1 – Receive the Request

All access requests must be submitted through the approved ticketing or workflow system.

Informal requests received through personal messages, verbal requests or unapproved channels must not be used as the sole basis for provisioning access.

Step 2 – Verify the Requester's Identity

The Helpdesk technician must verify that the request originates from an authorised requester.

The technician must not rely solely on an unverified email or message where additional verification is required.

Step 3 – Confirm Required Information

The ticket should contain:

- User's name.
- Department or team.
- Job role.
- Requested system.
- Required access level.
- Business justification.
- Requested start date.
- End date where temporary access is required.

- Manager approval.

Step 4 – Verify Manager Approval

The Helpdesk technician must verify that the user's manager has approved the requested access.

Where the requested access involves sensitive information, privileged permissions or a specific data owner, the relevant system or data owner approval must also be confirmed.

Step 5 – Determine the Appropriate Role

The technician should use the approved role or access catalogue to identify the appropriate permission level.

Access must be based on:

- Job responsibilities.
- Business need.
- Least privilege.
- Need-to-know principles.
- Sensitivity of the requested information.

Step 6 – Perform a Least-Privilege Check

Before provisioning access, the technician must confirm that:

- The requested access is necessary.
- The access level is appropriate.
- Excessive permissions are not being granted.
- Privileged access has received the required additional approval.

Step 7 – Create or Update the Account

The authorised technician creates or updates the account using approved organisational systems.

The technician must follow applicable identity and security standards.

Passwords, authentication credentials and other sensitive information must not be recorded in the ticket.

Step 8 – Assign Approved Permissions

Assign only the permissions approved in the request.

The technician must not provide additional access simply because it may be convenient or technically available.

Step 9 – Apply Required Security Controls

Where applicable, required authentication and security controls must be enabled before access is provided.

Examples may include:

- Multi-factor authentication.
- Device requirements.
- Privileged-account controls.
- Conditional access requirements.

Step 10 – Notify the User and Manager

Once provisioning is complete, notify the user and relevant manager through an approved communication channel.

The notification should confirm:

- Access granted.
- Relevant system or service.
- Effective date.
- Any applicable conditions.

Credentials must be communicated using an approved secure mechanism.

Step 11 – Capture Evidence

The technician must record sufficient evidence in the ticket, including:

- Approval evidence.
- Date and time of provisioning.
- Technician responsible.
- Access role assigned.
- Systems affected.
- Relevant verification or completion information.

Step 12 – Close the Ticket

The ticket may be closed once:

- Required approval has been verified.
- Access has been provisioned.
- Least-privilege checks are complete.
- Evidence has been recorded.
- User/manager notification has been completed.

3.5 Emergency Access Requests

Emergency access may be granted where delay would create a significant operational, security or safety risk.

Emergency access must:

1. Be authorised by the designated emergency approver.
2. Be limited to the minimum necessary permissions.
3. Be time-limited where possible.
4. Be documented in the ticket.
5. Be reviewed retrospectively.
6. Be removed when the emergency requirement ends.

Emergency access must not become a substitute for the normal access-request process.

3.6 Exceptional Requests

Requests that do not fit an approved role or access model must be escalated to the appropriate system or data owner and, where necessary, the Information Security Manager.

The request must include a business justification and risk assessment before approval.

3.7 Record Retention and Audit Trail

Access requests and approval evidence must be retained according to NexusTech's approved record-retention requirements.

Records must be sufficiently complete to demonstrate:

- Who requested access.
- Who approved access.
- What access was granted.
- Why access was required.
- When access was granted.
- Who performed the provisioning.

Access records should be available for authorised audit and compliance reviews.

EVIDENCE BUNDLE 4 – COMMUNICATION AND TRAINING PLAN

Task 4: Acceptable Use Policy Rollout Plan

4.1 Objective

The purpose of the rollout plan is to ensure that employees understand the new Acceptable Use Policy, know what is expected of them and can demonstrate that they have completed the required training and acknowledgement.

Simply distributing the policy document by email is insufficient because effective implementation requires communication, training, acknowledgement and follow-up.

4.2 Communication and Training Plan

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	Understand acceptable use, prohibited activities, personal use and incident reporting requirements.	Email, all-hands session, LMS module and intranet.	Information Security Manager / HR	Week 1	Electronic policy acknowledgement and training completion.	≥95% completion and acknowledgement.
IT Staff	Understand technical responsibilities, software restrictions, monitoring and escalation	Technical briefing and mandatory training.	IT Manager / Information Security Manager	Week 1	Training attendance and acknowledgement.	≥95% completion; knowledge-check ≥80%.

	requirements.					
Managers	Understand their responsibility for staff compliance, escalation and access-related decisions.	Management briefing and email guidance.	Information Security Manager	Week 1	Manager attestation.	100% management acknowledgment.
HR	Understand how policy violations connect to employee management and disciplinary processes.	HR briefing.	Information Security Manager / HR	Week 1	Meeting record and acknowledgment.	100% HR completion.
Contractors/ Third Parties	Understand applicable acceptable-use requirements before receiving access.	Contract documentation and onboarding briefing.	Procurement / IT / Security	Before access	Contractual acknowledgment.	100% acknowledgment before access.

4.3 Rollout Timeline

Week 1 – Announcement

- CEO announces the new policy.
- Policy is published in the official policy repository.
- Email communication is sent to affected users.
- Managers receive implementation guidance.

Week 2 – Training

- Mandatory AUP learning module is assigned.
- All-hands awareness session is conducted.
- IT and management receive role-specific briefings.

- Knowledge check is completed.

Week 3 – Acknowledgement

- Users formally acknowledge the policy.
- HR and managers receive completion reports.
- Outstanding users receive reminders.

Week 4 – Follow-Up

- Completion and acknowledgement rates are reviewed.
- Users who have not completed training are escalated.
- Frequently misunderstood requirements are identified.
- Additional clarification is provided where required.

4.4 Acknowledgement Mechanism

Employees must complete an electronic acknowledgement confirming that they:

1. Have received access to the Acceptable Use Policy.
2. Have read or completed the required training.
3. Understand their responsibilities.
4. Agree to comply with the policy.

The acknowledgement record should be retained in the appropriate HR, learning or policy-management system.

4.5 Rollout Effectiveness Measures

The following measures will be used:

Measure 1 – Training Completion

Target: At least 95% of required users complete training within the rollout period.

Measure 2 – Policy Acknowledgement

Target: At least 95% of required users acknowledge the policy.

Measure 3 – Knowledge Check

Target: At least 80% average score, with users below the required threshold completing additional learning.

Measure 4 – Policy-Related Incidents

The Information Security Manager will monitor whether incidents associated with unacceptable use decrease or whether repeated misunderstandings indicate a need for additional training.

4.6 Non-Compliance and Escalation

Users who do not complete mandatory training or acknowledgement will receive reminders.

Persistent non-compliance should be escalated through the user's manager and HR where appropriate.

Serious or deliberate violations of the Acceptable Use Policy may be investigated and handled according to the enforcement provisions of the policy.

EVIDENCE BUNDLE 5 – POLICY REVIEW AND MAINTENANCE MEMO

Task 5: Policy Review Memo

To: Information Security Steering Committee

From: Information Security Manager

Subject: Review of Acceptable Use Policy Following AWS Migration and Security Incident

Date: 18 September 2027

Policy Review Memo

The Acceptable Use Policy should be formally reviewed because two significant changes have occurred since its approval. First, NexusTech migrated its primary database to AWS, creating new cloud-service usage, access-management, data-handling and third-party security considerations. The existing policy should therefore be checked to determine whether its requirements adequately cover approved cloud services, secure handling of company and client information in cloud environments, authorised access and the use of personal cloud storage. Second, an employee shared a sensitive document through a personal cloud storage account. This incident demonstrates a practical gap or misunderstanding concerning the use of unauthorised storage services and should be considered as evidence when assessing the effectiveness and clarity of the current policy.

The review should involve the Information Security Manager, IT/Cloud representatives, data owners, HR, Legal/Privacy representatives where appropriate and relevant business managers. The review team should examine the incident record, existing policy requirements, cloud migration documentation, access controls, user feedback, training results and any related audit findings. At least two updates are recommended. First, the AUP should explicitly prohibit storing or sharing NexusTech or client information through personal cloud storage accounts unless formally authorised through an approved exception. Second, the policy should clarify that only approved cloud storage and collaboration services may be used for organisational information and that users must follow applicable classification and access requirements when using those services.

The Information Security Manager should remain the policy owner. The revised policy should undergo stakeholder consultation and risk review before being submitted to the designated approval authority, including the CEO where required by the governance framework. The policy should continue to be reviewed at least annually, with an early review triggered by significant technology or cloud changes, serious security incidents, material changes to legal or regulatory requirements, major audit findings or evidence that the policy is no longer effective.

CONCLUSION

The five evidence bundles establish a practical security policy framework for NexusTech Solutions.

The hierarchy separates policies, standards, procedures and guidelines so that high-level requirements are not mixed with technical instructions or general recommendations. The Acceptable Use Policy establishes clear expectations for employees and other authorised users, while the User Access Request Procedure translates access-control requirements into a consistent operational process.

The Communication and Training Plan provides a structured approach for implementing the AUP rather than relying solely on email distribution. Finally, the Policy Review Memo demonstrates how organisational changes and security incidents should trigger policy review and continuous improvement.

Together, these artefacts provide NexusTech with a maintainable foundation for stronger information security governance and continued development of its security policy framework.

REFERENCES

International Organization for Standardization (ISO). ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements.

International Organization for Standardization (ISO). ISO/IEC 27002 – Information security, cybersecurity and privacy protection – Information security controls.

National Institute of Standards and Technology (NIST). Cybersecurity Framework (CSF) 2.0.

NexusTech Solutions. Internal security governance and policy-development requirements provided in the GRC102 Week 2 laboratory scenario.